

Experiment 4

Hash Cracking using John the Ripper

AIM

To crack password hashes (MD5, SHA-1, SHA-256, NTLM) using John the Ripper in Kali Linux and understand dictionary attacks, brute-force attacks, and wordlist-based attacks on password hashes.

REQUIREMENTS

OS	Kali Linux 2024
Tool	John the Ripper (pre-installed), Hashcat (optional)
Wordlist	/usr/share/wordlists/rockyou.txt (default in Kali)
Hash Types	MD5, SHA-1, SHA-256, NTLM, bcrypt, SHA-512crypt
Privileges	Root access required for shadow file

THEORY

John the Ripper (JtR) is a free and open-source password security auditing and recovery tool. It is designed to detect weak Unix passwords but can also crack MD5, SHA hashes, ZIP files, SSH keys, and more.

Attack Mode	Description
Single Mode	Uses username variations to guess the password
Wordlist Mode	Uses a dictionary file (e.g., rockyou.txt) to crack hashes
Incremental Mode	Brute-forces all character combinations (thorough but slow)
External Mode	User-defined custom attack using C code

The rockyou.txt wordlist contains over 14 million commonly used passwords, leaked from the RockYou.com breach in 2009 and now the standard wordlist in penetration testing.

PROCEDURE

- Unzip rockyou.txt wordlist: `gunzip /usr/share/wordlists/rockyou.txt.gz`
- Create a test hash file with known passwords hashed as MD5.
- Use john with `--format=raw-md5` and `--wordlist` to crack MD5 hashes.
- View cracked passwords: `john --show hashfile.txt`
- Create `/etc/shadow` format file to crack Linux system passwords.
- Use `unshadow` command to combine `/etc/passwd` and `/etc/shadow`.

- Run John against the unshadowed file to crack Linux user passwords.
- Try SHA-256 hash cracking with --format=raw-sha256.
- Try NTLM hash cracking for Windows passwords.
- Use --incremental mode for brute force on short passwords only.

COMMANDS

```
# Unzip the rockyou wordlist
gunzip /usr/share/wordlists/rockyou.txt.gz
wc -l /usr/share/wordlists/rockyou.txt # 14344391 lines

# Create MD5 hash file
echo -n 'password123' | md5sum
echo '482c811da5d5b4bc6d497ffa98491e38' > hashes.txt

# Crack MD5 hashes using wordlist
john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt hashes.txt

# Show cracked results
john --show --format=raw-md5 hashes.txt

# Crack Linux shadow file
unshadow /etc/passwd /etc/shadow > unshadowed.txt
john --wordlist=/usr/share/wordlists/rockyou.txt unshadowed.txt

# Crack SHA-256 hash
echo -n 'letmein' | sha256sum > sha_hash.txt
john --format=raw-sha256 --wordlist=/usr/share/wordlists/rockyou.txt sha_hash.txt

# Brute-force mode (short passwords only!)
john --incremental --format=raw-md5 hashes.txt

# Check status
john --status
```

OUTPUT

```
root@kali:~# john --format=raw-md5 \
--wordlist=/usr/share/wordlists/rockyou.txt hashes.txt

Loaded 3 password hashes (Raw-MD5 [MD5 256/256 AVX2 8x3])
password (hash1)
123456 (hash2)
password123 (hash3)
3g 0:00:00:02 DONE 1.354g/s 5477Kp/s
Session completed

root@kali:~# john --show --format=raw-md5 hashes.txt
482c811da5d5b4bc6d497ffa98491e38:password123
5f4dcc3b5aa765d61d8327deb882cf99:password
e10adc3949ba59abbe56e057f20f883e:123456
3 password hashes cracked, 0 left
```

```
root@kali:~# john --show unshadowed.txt
root:toor:0:0:root:/root:/bin/bash
testuser:letmein:1001:1001:./home/testuser:/bin/sh
2 password hashes cracked, 0 left
```

RESULT

Hash cracking was performed successfully using John the Ripper. Three MD5 hashes were cracked using rockyou.txt wordlist in under 3 seconds. Linux shadow file passwords were also cracked (root: toor, testuser: letmein). This demonstrates the importance of using strong, unique passwords and proper salting mechanisms.